Lectura 10: Introduction to Database Security

Bases de datos II

Estudiante: Fabricio Monge Brenes Carnet: 2023108707

Instrucciones

Tiempo estimado de lectura: 35 minutos

¿En qué consiste SQL Injection?

¿En qué consiste Access Control?

Comente el rol de la Observabilidad en la seguridad de bases de datos

¿Cómo se encripta información en una base de datos?

Respuestas

¿En qué consiste SQL Injection?

El concepto de SQL injection se refiere a un tipo de ataque que se aprovecha de las manera en la que se construyen las consultas SQL en el código de la app, cuando los inputs no son validados correctamente. Permte insertar código en una consulta para:

- Obtener información no autorizada.
- Borrar o modificar datos maliciosamente.
- Insertar datos que den acceso no autorizado.

Se descrubitó al rededor de 1998 y es una gran preocupación en terminos de seguridad. Pero se puede evitar mediante lo siguiente:

- Evitar la construcción dinámica de SQL como cadena.
- Usar sentencias parametrizadas, como prepared statements de JDBC.
- Usar procedimientos almacenados, siempre que no construyan SQL dinámicamente.
- Validar la entrada del usuario.
- Limitar permisos de base de datos según necesidad.
- En algunos casos, como en Oracle, no se permiten cadenas con múltiples sentencias SQL separadas por punto y coma.

¿En qué consiste Access Control?

Es el proceso de asegurar que los datos o recursos se accedan solo de formas autorizadas. Esto incluye:

- Authorization: define quién tiene acceso y a qué datos.
- Identification: forma en que se identifica a los usuarios, como user ID, tarjetas inteligentes o biometría.

- Authentication: verificar que el usuario es quien dice ser, normalmente con contraseña, multifactor, etc.
- Accountability: capturar y mantener logs para trazabilidad.

Se puede representar con una matriz de control de acceso:

- Columnas: objetos de base de datos.
- Filas: individuos, roles, grupos o aplicaciones.
- Celdas: tipo de acceso permitido, como `READ`, `INSERT`, `UPDATE`, `DELETE`, `EXECUTE`, `CREATE`.

Se implementa con el lenguaje de autorización, por ejemplo `GRANT` y `REVOKE`. Además, las vistas también funcionan como mecanismo de control de acceso.

Comente el rol de la Observabilidad en la seguridad de bases de datos

La observabilidad permite encotnrar operaciones que se puedan considerar sospechozas, en usuarios autorizados y en usuarios no autorizados. En la lectura se mencionan ciertos aspectos de la Observabilidad que afectan a la seguiridad de bases de datos, como:

- Security log: registro de todos los intentos de violación de seguridad. Puede registrar el intento o enviar un mensaje inmediato al operador o al DBA.
- Audit trail: registra todos los accesos a la base de datos, incluyendo usuario, operación, workstation, hora exacta, dato afectado y valores anterior y nuevo.
- Triggers: pueden usarse para crear un audit trail de una tabla, registrando cambios, hora y usuario.
- Auditoría incorporada: Oracle cuenta con auditoría integrada para distintos tipos de audit trails.

¿Cómo se encripta información en una base de datos?

Los datos pueden almacenarse en forma encriptada en las bases de datos. Además los datos pueden encriptarse cuando se comunican a otros sitios. Un sistema de cifrado tiene: algoritmo de cifrado, clave de cifrado, algoritmo de descifrado, clave de escifrado. En el caso de Oracle, se puede usar DBMS_CRYPTO y Oracle Net Services para cifrado de red. Existen dos tipos de cifrado:

Cifrado simétrico: la clave de descifrado es la misma que la de cifrado.

- DES: clave de 56 bits sobre bloques de 64 bits.
- Triple DES o 3DES: usa tres claves y aplica DES tres veces.
- AES: claves de 128, 192 o 256 bits, bloques de 128 bits y cuatro rondas de transformaciones.

Cifrado de clave pública o asimétrico:

- Usa una clave pública y una privada.
- Para cada usuario se eligen primos (p, q) como clave privada, y p * q como clave pública.
- Un método conocido es RSA.